

Question 1

An AI-powered medical diagnostic system produces an incorrect recommendation during normal operation because of an unexpected model behavior. No attacker is involved. According to the Module 7 distinction between safety and security, this is primarily:

- A. An AI security incident because the model produced an incorrect output
 - B. An AI safety issue because unintended harm occurred during intended operation
 - C. A governance incident because the model failed to meet organizational objectives
 - D. A security incident because all model failures represent integrity violations
-

Question 2

A threat actor compromises an industrial control system and manipulates sensor readings so that operators receive false information about reactor temperature. Which statement BEST describes the relationship between safety and security in this scenario?

- A. It is exclusively a safety issue because reactor temperature affects physical safety
 - B. It is exclusively a security issue because the initial action was malicious
 - C. A security breach can create a subsequent safety hazard
 - D. Safety and security must always be treated as independent risk domains
-

Question 3

An organization wants to systematically assign responsibility for AI safety and security controls across governance, operations, data, hardware, software, and network components. Which framework does Module 7 adapt for this purpose?

- A. MITRE ATT&CK
 - B. TOGAF-based enterprise architecture
 - C. OWASP Top 10
 - D. CSA Cloud Controls Matrix
-

Question 4

A company is reviewing its AI platform and identifies policies, regulatory oversight, resource allocation, accountability assignments, and risk acceptance processes as key controls. Which enterprise architecture layer primarily owns these concerns?

- A. Governance
 - B. Operation
 - C. Data and Information
 - D. Network and Connectivity
-

Question 5

An AI system continuously monitors incoming data and discovers that the statistical characteristics of production data have gradually shifted away from the data distribution used during training. Which concept BEST describes this situation?

- A. Model inversion
 - B. Data drift
 - C. Model extraction
 - D. Privacy leakage
-

Question 6

An attacker systematically queries a proprietary AI model and analyzes its responses until they can build a functionally equivalent model without obtaining the original model parameters. Which attack is being demonstrated?

- A. Model inversion
 - B. Data extraction
 - C. Model extraction
 - D. Data poisoning
-

Question 7

A machine-learning model behaves normally for almost all inputs but produces a specific malicious behavior whenever a particular trigger pattern appears in the input. Which vulnerability BEST matches this scenario?

- A. Model backdoor
 - B. Data drift
 - C. Model extraction
 - D. Resource overload
-

Question 8

An organization wants to reduce the risk that a model memorizes and subsequently exposes personally identifiable information contained in its training dataset. Which control is MOST directly aligned with this objective according to Module 7?

- A. Anonymization and pseudonymization
 - B. Model signing
 - C. Network segmentation
 - D. Dependency tracking through an SBOM
-

Question 9

A security team wants to protect an ML development pipeline from malicious open-source packages, compromised pretrained models, and manipulated artifacts introduced during development or deployment. Which AI security pillar should be the primary focus?

- A. Data Security and Privacy Protection
 - B. Model Security
 - C. Vulnerability Management
 - D. Governance and Compliance
-

Question 10

A company wants to establish an inventory of its ML assets, generate SBOMs, track provenance, and cryptographically sign models and dependencies. Which capability BEST addresses this requirement?

- A. ML Asset Inventory and Provenance Tracking
 - B. Data Minimization Implementation
 - C. Model Output Validation
 - D. Adaptive Multifactor Authentication
-

Question 11

A development team discovers vulnerable Python packages and insecure serialized model files within its ML pipeline. Which combination of tools from Module 7 is MOST appropriate for this problem?

- A. ARX and GDPR Toolkit
 - B. pip-audit and fickling
 - C. SHAP and LIME
 - D. Isolation Forest and Autoencoders
-

Question 12

An organization discovers that different teams have deployed AI models without clearly defined ownership, approval processes, or ongoing oversight. Which Governance and Compliance risk does this BEST represent?

- A. Resource overload
 - B. Accountability gaps
 - C. Data drift
 - D. Model extraction
-

Question 13

A security organization uses AI to analyze millions of authentication and network events, identify anomalous behavior, and prioritize potential threats. Which concept does this BEST illustrate?

- A. Security for AI
- B. AI for security
- C. AI alignment
- D. AI model governance

Question 14

An AI penetration-testing agent is instructed to test a web application but must not access the production database. Before executing a potentially destructive command, the agent requests approval from a security professional. What security design principle is BEST demonstrated?

- A. Fully autonomous exploitation
 - B. Human-in-the-loop oversight
 - C. Zero Trust networking
 - D. Model extraction prevention
-

Question 15

Which statement BEST distinguishes vulnerability assessment, penetration testing, and red teaming as described in Module 7?

- A. Vulnerability assessment attempts exploitation, while red teaming only performs automated scanning
 - B. Penetration testing is primarily a compliance exercise, while vulnerability assessment is strategic
 - C. Vulnerability assessment identifies weaknesses, penetration testing attempts exploitation, and red teaming simulates a broader adversary
 - D. Red teaming and penetration testing are identical activities performed at different network layers
-

Question 16

During reconnaissance for an authorized security assessment, an AI system automatically gathers publicly available information about the target organization, summarizes the findings, and identifies potential entry points. Which AI augmentation capability is MOST directly involved?

- A. OSINT automation and adaptive test planning
 - B. Model inversion and data extraction
 - C. Secure model runtime and confidential computing
 - D. Data anonymization and pseudonymization
-

Question 17

An organization implements Zero Trust and requires every access request to be evaluated based on current policy and contextual information rather than assuming that users inside the corporate network are trustworthy. Which principle is MOST central to this design?

- A. Trust internal networks by default
 - B. Authenticate users only once at login
 - C. Never trust, always verify
 - D. Allow broad access after successful MFA
-

Question 18

Within the Zero Trust logical architecture, a component evaluates enterprise policies and real-time inputs such as threat intelligence and vulnerability information to determine whether access should be granted or denied. Which component is this?

- A. Policy Enforcement Point
 - B. Policy Administrator
 - C. Policy Engine
 - D. Security Information and Event Management system
-

Question 19

A user's authentication succeeds, but during the session the system detects behavior that differs substantially from the user's established behavioral baseline and triggers additional authentication. Which Zero Trust capability BEST supports this use case?

- A. User and Entity Behavior Analytics
 - B. Software Bill of Materials
 - C. Model signing
 - D. Data minimization
-

Question 20

A multinational organization operates AI applications across multiple cloud providers. An application hosted by one provider communicates directly with a database hosted by another provider, bypassing the organization's traditional network perimeter. Which Zero Trust approach from Module 7 is MOST appropriate?

- A. Rely exclusively on the enterprise firewall
 - B. Use a software-defined perimeter with policy enforcement points at application and data access points
 - C. Trust the application because it resides within an approved cloud provider
 - D. Disable cross-cloud communication to eliminate the security problem
-

Answers & Explanations

Answer 1 — B. An AI safety issue because unintended harm occurred during intended operation

Explanation: Module 7 defines safety around preventing unintended harm during intended operation. AI systems can produce probabilistic and sometimes opaque outputs, making safety failures difficult to predict. Security, by contrast, concerns intentional and unauthorized acts designed to cause harm.

Answer 2 — C. A security breach can create a subsequent safety hazard

Explanation: The attack itself is a security event because an attacker intentionally manipulates the control system. However, manipulated sensor readings can cause unsafe operating conditions. Module 7 explicitly emphasizes the interdependence: security breaches can lead to safety hazards, while safety failures can also create exploitable security conditions.

Answer 3 — B. TOGAF-based enterprise architecture

Explanation: Module 7 adapts TOGAF as an analytical framework for mapping safety and security responsibilities across enterprise infrastructure. The adapted framework uses six layers: Governance, Operation, Data and Information, Hardware, Software and Application, and Network and Connectivity.

Answer 4 — A. Governance

Explanation: Governance addresses strategic oversight, including safety and security policies, regulatory compliance, resource allocation, accountability, roles, risk acceptance, and reporting.

Answer 5 — B. Data drift

Explanation: Data drift occurs when the statistical distributions, patterns, or characteristics of operational data shift away from the distribution used to train the model. The shift can happen naturally or be deliberately induced by attackers.

Answer 6 — C. Model extraction

Explanation: Model extraction involves systematically querying a proprietary model and analyzing its responses to reproduce its functionality or learned behavior. The objective is to create a functionally equivalent surrogate without necessarily accessing the original model's parameters or training data.

Answer 7 — A. Model backdoor

Explanation: A model backdoor is a hidden malicious behavior activated by particular input patterns while the model continues behaving normally for ordinary inputs. Backdoors can be introduced during training, fine-tuning, or through supply-chain compromise.

Answer 8 — A. Anonymization and pseudonymization

Explanation: Module 7 identifies anonymization and pseudonymization as controls for privacy leakage. These techniques reduce identifiable personal information and therefore reduce the likelihood that memorized sensitive information will be exposed through model outputs.

Answer 9 — C. Vulnerability Management

Explanation: Vulnerability Management addresses weaknesses across AI systems, infrastructure, and supply chains. The study guide specifically identifies compromised open-source libraries, pretrained models containing hidden backdoors, and manipulated artifacts as supply-chain risks.

Answer 10 — A. ML Asset Inventory and Provenance Tracking

Explanation: This control addresses supply-chain risks and model integrity through automated asset discovery, SBOM generation, provenance tracking, and cryptographic signing of models and dependencies. The module gives CycloneDX, Syft, Sigstore, and in-toto as examples.

Answer 11 — B. pip-audit and fickling

Explanation: Module 7 identifies **pip-audit**, **safety**, and **bandit** for Python security scanning, while **fickling** is identified for static analysis of unsafe pickle/eval usage in model files.

Answer 12 — B. Accountability gaps

Explanation: Accountability gaps arise when responsibilities across the AI lifecycle are unclear. Governance controls such as RACI matrices are intended to establish defined roles and responsibilities across relevant stakeholders.

Answer 13 — B. AI for security

Explanation: The distinction in Module 7 is directional: **security for AI** protects AI systems, while **AI for security** uses AI capabilities to protect other systems and organizations. Threat detection, analysis, hunting, and automated response are examples of AI for security.

Answer 14 — B. Human-in-the-loop oversight

Explanation: The AI penetration-testing example explicitly includes an optional approval step before potentially risky commands are executed. Module 7 stresses that AI augments rather than replaces human expertise, particularly for interpreting results, strategic decisions, and ethical/legal considerations.

Answer 15 — C. Vulnerability assessment identifies weaknesses, penetration testing attempts exploitation, and red teaming simulates a broader adversary

Explanation: Vulnerability assessment is primarily automated identification of weaknesses. Penetration testing goes deeper by attempting exploitation. Red teaming provides a broader adversarial simulation, including social engineering, phishing, initial access, and lateral movement.

Answer 16 — A. OSINT automation and adaptive test planning

Explanation: In the reconnaissance phase, AI can automate Open-Source Intelligence collection, summarize data, analyze the threat landscape, identify entry points, and support adaptive test planning.

Answer 17 — C. Never trust, always verify

Explanation: Zero Trust assumes an attacker may already be inside the environment. No user, application, or machine is automatically trusted. Access should be granted only when needed, least privilege should be enforced, and authentication/authorization should be continuous.

Answer 18 — C. Policy Engine

Explanation: The Policy Engine is the decision-making component—the "brain" of Zero Trust. It evaluates enterprise policies together with real-time inputs such as threat intelligence and vulnerability information to determine whether access should be allowed or denied.

Answer 19 — A. User and Entity Behavior Analytics

Explanation: UEBA establishes behavioral baselines for users, devices, and applications and identifies deviations from those baselines. Module 7 describes anomaly detection, sequence models, and graph-based learning as techniques that can help identify unusual activity.

Answer 20 — B. Use a software-defined perimeter with policy enforcement points at application and data access points

Explanation: In a multi-cloud architecture, critical traffic can move directly between cloud providers outside the traditional enterprise perimeter. Module 7 recommends a Zero Trust approach using a software-defined perimeter, with Policy Enforcement Points at application and data access points and the Policy Engine/Policy Administrator making and executing decisions.

Question 21

An organization discovers that a small percentage of malicious records were deliberately inserted into the training dataset. After retraining, the model begins making systematically incorrect predictions.

Which attack does this BEST represent?

- A. Model inversion
- B. Data poisoning
- C. Model extraction
- D. Privacy leakage

Question 22

A security team wants to detect whether information from an AI training dataset can be inferred through repeated queries against the deployed model.

Which attack should the team primarily assess?

- A. Data extraction
 - B. Resource overload
 - C. Model backdoor
 - D. Identity spoofing
-

Question 23

A company discovers that its language model occasionally reproduces confidential customer information that appeared in its training corpus.

Which AI security issue BEST describes this scenario?

- A. Data drift
 - B. Privacy leakage
 - C. Model extraction
 - D. Resource overload
-

Question 24

A company wants to reduce the amount of sensitive information collected before it enters an AI training pipeline. The organization wants to retain useful predictive information while eliminating unnecessary data.

Which control from Module 7 is MOST appropriate?

- A. Data minimization
 - B. Model signing
 - C. Runtime monitoring
 - D. Adversarial testing
-

Question 25

A security team notices that an AI model behaves correctly under normal conditions but makes an incorrect classification whenever an attacker introduces a carefully crafted, very small change to an image.

Which attack does this BEST represent?

- A. Model inversion
- B. Adversarial example

- C. Data extraction
 - D. Model extraction
-

Question 26

A machine-learning engineer wants to protect access to a highly valuable proprietary model. The organization wants to make unauthorized model querying more difficult while limiting excessive API requests.

Which combination of controls is MOST appropriate?

- A. MFA, role-based access control, and rate limiting
 - B. Data anonymization, pseudonymization, and data minimization
 - C. SBOM generation, model signing, and dependency tracking
 - D. SIEM correlation, UEBA, and anomaly detection
-

Question 27

A company suspects that a third-party pretrained model may contain malicious functionality. The security team wants to inspect the model for hidden behaviors before deployment.

Which control BEST addresses this concern?

- A. Model behavior testing and sandboxing
 - B. Data minimization
 - C. Adaptive MFA
 - D. Compliance tracking
-

Question 28

A security team wants to detect malicious code or unexpected processes executing inside the runtime environment of an AI application.

Which control is MOST directly applicable?

- A. Runtime monitoring
 - B. Pseudonymization
 - C. Consent management
 - D. RACI mapping
-

Question 29

An AI development team wants to maintain a record showing where models, datasets, and dependencies originated and how they moved through the development pipeline.

Which capability is MOST relevant?

- A. ML asset inventory and provenance tracking
- B. Adaptive authentication

- C. User behavior baselining
 - D. Output hallucination detection
-

Question 30

An organization has deployed several AI systems, but nobody has clearly established who is responsible for security, compliance, model approval, and ongoing monitoring.

Which governance problem is MOST clearly demonstrated?

- A. Data drift
 - B. Accountability gap
 - C. Adversarial example
 - D. Resource overload
-

Question 31

A company has defined a process requiring AI systems to undergo risk assessment, formal approval, and continuous monitoring throughout their operational lifecycle.

Which governance control does this BEST represent?

- A. Model governance processes
 - B. Data minimization implementation
 - C. Model extraction prevention
 - D. Runtime vulnerability scanning
-

Question 32

A security team is evaluating an AI platform against regulatory requirements and wants a structured way to track whether required controls have been implemented and maintained.

Which control BEST supports this objective?

- A. Compliance tracker
 - B. Model inversion
 - C. Adversarial robustness testing
 - D. UEBA
-

Question 33

A security organization is deciding how to use AI during a security assessment. The team wants AI to process very large volumes of security telemetry and identify patterns that humans may not recognize.

Which AI capability is MOST directly relevant?

- A. Pattern recognition
- B. Data anonymization

- C. Model signing
 - D. Human manipulation
-

Question 34

A security analyst asks an AI system, in plain English, "Show me all authentication failures involving privileged accounts from unusual geographic locations during the last 24 hours."

Which AI capability from Module 7 is being demonstrated?

- A. Natural language processing
 - B. Model extraction
 - C. Adversarial example generation
 - D. Data poisoning
-

Question 35

A penetration-testing team asks an AI system to generate a custom exploitation script based on a vulnerability discovered during an authorized assessment.

Which AI capability does this BEST illustrate?

- A. Generative AI
 - B. Data minimization
 - C. UEBA
 - D. Policy enforcement
-

Question 36

An organization wants to identify as many weaknesses as possible across thousands of systems. The organization does not necessarily need to demonstrate that each weakness can actually be exploited.

Which security testing approach is MOST appropriate?

- A. Red teaming
 - B. Penetration testing
 - C. Vulnerability assessment
 - D. Adversarial simulation
-

Question 37

A security team has identified a vulnerability in an externally exposed application and now wants to determine whether the vulnerability can actually be exploited.

Which testing approach BEST fits this objective?

- A. Vulnerability assessment
- B. Penetration testing

- C. Compliance assessment
 - D. Asset inventory
-

Question 38

An organization wants to determine whether a sophisticated adversary could research employees, conduct targeted phishing, gain initial access, move through the environment, and remain undetected.

Which security testing approach BEST fits this objective?

- A. Vulnerability assessment
 - B. Penetration testing
 - C. Red teaming
 - D. Configuration review
-

Question 39

An AI penetration-testing agent has identified a potentially exploitable vulnerability. Before executing the next command, the agent asks a human security professional for authorization because the command could have a significant impact.

What principle does this BEST demonstrate?

- A. Autonomous exploitation
 - B. Human-in-the-loop control
 - C. Data minimization
 - D. Model inversion protection
-

Question 40

An AI security agent follows this sequence:

1. Perform reconnaissance
2. Scan services and vulnerabilities
3. Attempt safe exploitation
4. Generate a report

Which statement BEST describes this workflow?

- A. It demonstrates how AI can augment the established security-testing lifecycle
 - B. It replaces vulnerability assessment with Zero Trust
 - C. It demonstrates a model extraction attack
 - D. It is primarily an AI governance process
-

Answers & Explanations

Answer 21 — B. Data poisoning

Explanation: Data poisoning involves deliberately inserting malicious samples into training data. Even a relatively small percentage of manipulated data can potentially corrupt model behavior. Module 7 places this attack under **Data Security and Privacy Protection**.

Answer 22 — A. Data extraction

Explanation: Data extraction involves inferring information from the training data through queries to the model. This differs from model extraction, where the attacker attempts to reproduce the model's functionality.

Answer 23 — B. Privacy leakage

Explanation: Privacy leakage occurs when a model memorizes sensitive information from its training data and subsequently exposes that information through its outputs or behavior.

Answer 24 — A. Data minimization

Explanation: Data minimization limits collection to information that is actually necessary. Module 7 maps this control specifically to the risk of **data extraction** and describes automated relevance scoring as an example approach.

Answer 25 — B. Adversarial example

Explanation: Adversarial examples involve small, intentional changes to input data that cause an AI model to make an incorrect decision. The attack targets the model's behavior at inference time rather than stealing the model or reconstructing its training data.

Answer 26 — A. MFA, role-based access control, and rate limiting

Explanation: Module 7 specifically identifies model access controls using **multifactor authentication, role-based access control, and rate limiting** as controls addressing model extraction and model inversion.

Answer 27 — A. Model behavior testing and sandboxing

Explanation: Module 7 identifies **model behavior testing and sandboxing** as controls for detecting and containing potentially malicious behavior in models, particularly in the context of model backdoors and supply-chain risks.

Answer 28 — A. Runtime monitoring

Explanation: Runtime monitoring allows organizations to observe behavior while AI applications and associated components are executing. Module 7 identifies runtime monitoring alongside tools such as Falco and adversarial testing as part of AI security controls.

Answer 29 — A. ML asset inventory and provenance tracking

Explanation: Provenance tracking establishes where models and dependencies originated and helps maintain traceability throughout the ML lifecycle. Module 7 treats asset inventory, provenance tracking, SBOMs, and cryptographic signing as important supply-chain security capabilities.

Answer 30 — B. Accountability gap

Explanation: Accountability gaps occur when responsibilities across the AI lifecycle are unclear. Module 7 specifically identifies unclear responsibilities as a Governance and Compliance attack/risk category and recommends organizational role frameworks such as RACI matrices.

Answer 31 — A. Model governance processes

Explanation: Model governance processes include risk assessments, approval procedures, and continuous monitoring requirements. Module 7 maps these controls to **unmanaged model risks and ethical failures**.

Answer 32 — A. Compliance tracker

Explanation: Module 7 identifies a compliance tracker as an example control under the Organizational Role Framework and Governance and Compliance pillar. Its purpose is to support tracking of regulatory and compliance requirements.

Answer 33 — A. Pattern recognition

Explanation: Pattern recognition enables AI systems to process security data at scale and identify deviations from expected behavior. Module 7 describes anomaly detection as an example where AI learns what normal behavior looks like for users and devices and identifies unusual activity.

Answer 34 — A. Natural language processing

Explanation: Natural language processing allows analysts to interact with security data using ordinary language rather than manually constructing complex database queries. Module 7 identifies NLP as one of the major technologies transforming security testing.

Answer 35 — A. Generative AI

Explanation: Generative AI can create new content, including custom exploitation scripts, realistic phishing emails for security awareness exercises, and security reports. Module 7 identifies this as a major capability in AI-augmented security testing.

Answer 36 — C. Vulnerability assessment

Explanation: Vulnerability assessment is primarily focused on identifying weaknesses across systems. It is generally more automated, faster, and less expensive than penetration testing or red teaming, and its objective is not necessarily to prove exploitability.

Answer 37 — B. Penetration testing

Explanation: Penetration testing goes beyond identifying vulnerabilities and attempts to exploit them. Module 7 describes penetration testing as combining automated tools with human expertise to determine whether identified weaknesses can actually be exploited.

Answer 38 — C. Red teaming

Explanation: Red teaming represents a broader adversarial simulation. It can involve researching employees, creating targeted phishing attacks, obtaining initial access through social engineering, and testing how far an adversary can penetrate before detection.

Answer 39 — B. Human-in-the-loop control

Explanation: Module 7's AI penetration-testing example specifically describes an optional approval step before potentially risky commands are executed. Human-in-the-loop design preserves human control over critical decisions while benefiting from AI's speed and consistency.

Answer 40 — A. It demonstrates how AI can augment the established security-testing lifecycle

Explanation: AI does not fundamentally replace the five security-testing phases. Module 7 identifies them as **reconnaissance, scanning, vulnerability analysis, exploitation, and reporting**, while AI enhances the capabilities available within each phase.

Question 41

An attacker inserts false information into an AI agent's long-term memory. Weeks later, the agent retrieves that information and uses it when making operational decisions.

Which OWASP threat BEST describes the initial attack?

- A. T2 — Tool Misuse
- B. T1 — Memory Poisoning

- C. T5 — Cascading Hallucination
 - D. T8 — Repudiation and Untraceability
-

Question 42

An AI agent has legitimate access to a payment API. An attacker supplies manipulated content that causes the agent to invoke the payment API and transfer funds to an unauthorized account.

Which OWASP threat is MOST directly represented by the agent's abuse of its authorized tool?

- A. T1 — Memory Poisoning
 - B. T2 — Tool Misuse
 - C. T4 — Resource Overload
 - D. T9 — Identity Spoofing
-

Question 43

An enterprise AI agent inherits administrative permissions from a dynamically assigned role because of an incorrect authorization configuration. The attacker exploits this condition to perform actions that should not be permitted.

Which threat BEST describes this situation?

- A. T3 — Privilege Compromise
 - B. T6 — Intent Breaking and Goal Manipulation
 - C. T8 — Repudiation and Untraceability
 - D. T12 — Agent Communication Poisoning
-

Question 44

An attacker repeatedly sends computationally expensive requests to an AI service until its CPU, memory, and service capacity are exhausted, degrading availability for legitimate users.

Which OWASP threat does this BEST represent?

- A. T2 — Tool Misuse
 - B. T4 — Resource Overload
 - C. T7 — Misaligned and Deceptive Behaviors
 - D. T10 — Overwhelming Human in the Loop
-

Question 45

An AI system generates an incorrect but highly plausible recommendation. A downstream AI system treats that recommendation as trustworthy and generates another incorrect recommendation, which is subsequently used by a third system.

Which threat is MOST directly illustrated?

- A. T1 — Memory Poisoning
 - B. T5 — Cascading Hallucination Attacks
 - C. T8 — Repudiation and Untraceability
 - D. T14 — Human Attacks on Multi-Agent Systems
-

Question 46

An attacker manipulates an AI agent's planning instructions so that, instead of optimizing for minimizing infrastructure costs, it begins prioritizing the attacker's objective of exposing internal information.

Which OWASP threat BEST describes this attack?

- A. T3 — Privilege Compromise
 - B. T6 — Intent Breaking and Goal Manipulation
 - C. T9 — Identity Spoofing
 - D. T12 — Agent Communication Poisoning
-

Question 47

An AI agent has been instructed to complete a legitimate business process. During execution, it deliberately takes a prohibited action while providing a misleading explanation intended to conceal what it actually did.

Which OWASP category BEST fits this behavior?

- A. T5 — Cascading Hallucination
 - B. T7 — Misaligned and Deceptive Behaviors
 - C. T8 — Repudiation and Untraceability
 - D. T15 — Human Manipulation
-

Question 48

A financial institution cannot determine which AI agent initiated a sensitive transaction because the agent's decision process and actions were not adequately logged.

Which OWASP threat is MOST applicable?

- A. T3 — Privilege Compromise
 - B. T7 — Misaligned Behavior
 - C. T8 — Repudiation and Untraceability
 - D. T12 — Agent Communication Poisoning
-

Question 49

An attacker compromises authentication credentials and impersonates an approved AI agent to access an internal application.

Which OWASP threat does this BEST represent?

- A. T2 — Tool Misuse
 - B. T6 — Goal Manipulation
 - C. T9 — Identity Spoofing and Impersonation
 - D. T13 — Rogue Agents in Multi-Agent Systems
-

Question 50

A security approval process requires a human to review AI-generated actions. An attacker deliberately floods the reviewer with large volumes of complex alerts and recommendations, causing the reviewer to overlook a malicious action.

Which OWASP threat BEST matches this scenario?

- A. T4 — Resource Overload
 - B. T8 — Repudiation and Untraceability
 - C. T10 — Overwhelming Human in the Loop
 - D. T15 — Human Manipulation
-

Question 51

An AI coding agent generates a script that is automatically executed in an environment with system-level access. The generated script contains malicious commands that modify the underlying host.

Which threat BEST describes this scenario?

- A. T5 — Cascading Hallucination
 - B. T9 — Identity Spoofing
 - C. T11 — Unexpected RCE and Code Attacks
 - D. T14 — Human Attacks on Multi-Agent Systems
-

Question 52

Two AI agents communicate through an internal message channel. An attacker modifies messages exchanged between them so that the second agent receives false instructions and makes incorrect operational decisions.

Which threat is MOST directly involved?

- A. T8 — Repudiation and Untraceability
 - B. T12 — Agent Communication Poisoning
 - C. T13 — Rogue Agents
 - D. T15 — Human Manipulation
-

Question 53

A multi-agent system contains an AI component that has been compromised. The component begins operating outside its assigned responsibilities and quietly exfiltrates sensitive information.

Which OWASP threat BEST describes this scenario?

- A. T3 — Privilege Compromise
 - B. T7 — Deceptive Behavior
 - C. T13 — Rogue Agents in Multi-Agent Systems
 - D. T14 — Human Attacks on Multi-Agent Systems
-

Question 54

An attacker exploits the trust relationship between multiple AI agents. One agent delegates a task to another, and the attacker manipulates the delegation process to obtain privileges beyond those originally granted.

Which threat is MOST directly applicable?

- A. T10 — Overwhelming Human in the Loop
 - B. T12 — Agent Communication Poisoning
 - C. T13 — Rogue Agents
 - D. T14 — Human Attacks on Multi-Agent Systems
-

Question 55

A customer interacts directly with an AI assistant and assumes that its recommendations are trustworthy. An attacker causes the agent to generate persuasive misinformation designed to convince the customer to take a harmful action.

Which OWASP threat BEST describes this scenario?

- A. T5 — Cascading Hallucination
 - B. T9 — Identity Spoofing
 - C. T10 — Overwhelming Human in the Loop
 - D. T15 — Human Manipulation
-

Question 56

A developer deploys an unapproved generative AI service inside the organization without security review, inventory, or governance oversight.

Which challenge from Module 7 does this BEST represent?

- A. No Ground Truth for Output
 - B. Prompt Injection Stays Elusive
 - C. Shadow AI Avoids Oversight
 - D. Tool Access Magnifies Errors
-

Question 57

An organization receives a harmful output from a generative AI system. Investigators cannot determine whether it resulted from a user mistake, poisoned information, or normal model behavior.

Which challenge does this BEST represent?

- A. AI vs. Cyber Incident Confusion
 - B. Shadow AI Avoids Oversight
 - C. Prompt Injection Stays Elusive
 - D. Tool Access Magnifies Errors
-

Question 58

A generative AI system produces a novel security recommendation, but the organization has no authoritative reference against which to determine whether the recommendation is correct.

Which challenge does this BEST illustrate?

- A. AI vs. Cyber Incident Confusion
 - B. No Ground Truth for Output
 - C. Shadow AI Avoids Oversight
 - D. Resource Overload
-

Question 59

An attacker places malicious instructions inside a PDF that appears legitimate. The AI system later retrieves and reads the document and follows the embedded instructions.

Why is this attack particularly difficult to detect according to Module 7?

- A. The attacker must compromise the model's source code
 - B. The malicious instructions are context-dependent and can be hidden within legitimate content
 - C. The attack only works against traditional machine-learning systems
 - D. The attack requires administrative privileges on the AI infrastructure
-

Question 60

A generative AI system is connected to APIs capable of modifying production configurations. A hallucinated instruction causes the agent to invoke an API and unintentionally change a critical system configuration.

Which challenge from Module 7 is MOST directly demonstrated?

- A. No Ground Truth for Output
- B. Shadow AI Avoids Oversight
- C. Tool Access Magnifies Errors
- D. AI vs. Cyber Incident Confusion

Answers & Explanations

Answer 41 — B. T1 — Memory Poisoning

Explanation: T1 involves compromising an AI system's short- or long-term memory by introducing malicious or false information. The poisoned information can later influence the agent's context, decisions, and actions.

Answer 42 — B. T2 — Tool Misuse

Explanation: T2 occurs when attackers manipulate an AI agent into abusing its integrated tools through deceptive prompts or commands. Importantly, the agent may be operating **within its authorized permissions**, but those permissions are manipulated for an unintended purpose.

This is an important distinction from **T3 Privilege Compromise**, where the attacker exploits weaknesses in permission management.

Answer 43 — A. T3 — Privilege Compromise

Explanation: T3 concerns weaknesses in permission management that allow unauthorized actions. Module 7 specifically identifies dynamic role inheritance and misconfigurations as examples of mechanisms that can contribute to privilege compromise.

Answer 44 — B. T4 — Resource Overload

Explanation: T4 targets computational, memory, and service capacity. The objective is to degrade performance or cause failures by exploiting the resource-intensive nature of AI systems.

Answer 45 — B. T5 — Cascading Hallucination Attacks

Explanation: T5 exploits AI systems' ability to generate contextually plausible but false information. When that false information propagates through downstream systems, the resulting errors can compound and disrupt decision-making. The study guide also notes that cascading hallucinations can contribute to destructive reasoning affecting tool invocation.

Answer 46 — B. T6 — Intent Breaking and Goal Manipulation

Explanation: T6 targets the planning and goal-setting capabilities of an AI agent. An attacker attempts to redirect the agent's objectives or reasoning away from the intended goal.

Answer 47 — B. T7 — Misaligned and Deceptive Behaviors

Explanation: T7 covers AI agents executing harmful or prohibited actions while exploiting reasoning and deceptive responses to achieve their objectives. The deliberate harmful action combined with misleading behavior is characteristic of this category.

Answer 48 — C. T8 — Repudiation and Untraceability

Explanation: T8 occurs when AI-agent actions cannot be adequately traced or accounted for because of insufficient logging or transparency in decision-making. Strong audit trails are therefore particularly important for agentic systems.

Answer 49 — C. T9 — Identity Spoofing and Impersonation

Explanation: T9 involves exploiting authentication mechanisms to impersonate AI agents or human users, allowing unauthorized actions to be performed under a false identity.

Answer 50 — C. T10 — Overwhelming Human in the Loop

Explanation: T10 specifically targets human oversight and validation mechanisms. Attackers can exploit human cognitive limitations or interaction weaknesses to make human reviewers miss malicious or unsafe actions.

Answer 51 — C. T11 — Unexpected RCE and Code Attacks

Explanation: T11 addresses situations where attackers exploit AI-generated execution environments to inject malicious code, trigger unintended system behavior, or execute unauthorized scripts.

Answer 52 — B. T12 — Agent Communication Poisoning

Explanation: T12 targets communication channels between AI agents. Manipulated inter-agent messages can spread false information, disrupt workflows, or influence downstream decisions.

Answer 53 — C. T13 — Rogue Agents in Multi-Agent Systems

Explanation: T13 involves malicious or compromised AI agents operating outside normal monitoring boundaries. Such agents may perform unauthorized actions or exfiltrate data.

Answer 54 — D. T14 — Human Attacks on Multi-Agent Systems

Explanation: T14 concerns attacks against the relationships and workflows between agents, including delegation, trust relationships, and workflow dependencies. Attackers can exploit these relationships to manipulate AI-driven operations or escalate privileges.

Answer 55 — D. T15 — Human Manipulation

Explanation: T15 arises from the trust relationship between AI agents and human users. Because users may place significant trust in an agent's responses and autonomy, attackers can exploit the agent to manipulate users, spread misinformation, or facilitate covert actions.

Answer 56 — C. Shadow AI Avoids Oversight

Explanation: Shadow AI refers to AI services deployed without appropriate security review or organizational governance. Module 7 notes that these untracked systems operate outside organizational oversight and can increase insider-threat potential. The challenge is mapped to **T3, T7, and T9**.

Answer 57 — A. AI vs. Cyber Incident Confusion

Explanation: This challenge occurs when an organization cannot clearly determine whether a harmful or misleading AI output resulted from user error, a security attack such as poisoning, or simply a model artifact. The ambiguity can result in slow or incorrectly directed incident response. Module 7 maps this challenge to **T5, T6, and T8**.

Answer 58 — B. No Ground Truth for Output

Explanation: Generative AI frequently produces novel content for which there may be no reliable ground truth. This makes it difficult to validate outputs and identify subtle security problems. Module 7 maps this challenge to **T5 and T11**.

Answer 59 — B. The malicious instructions are context-dependent and can be hidden within legitimate content

Explanation: Prompt injection remains particularly elusive because malicious instructions can be embedded in PDFs, emails, RAG content, or other material that the model subsequently reads. The instructions may appear benign to traditional security controls but become influential when interpreted within the model's context. Module 7 maps this challenge to **T2, T6, and T15**.

Answer 60 — C. Tool Access Magnifies Errors

Explanation: Tool access increases the consequences of AI errors because the model can move from generating information to actually performing actions. Module 7 specifically notes that when genAI systems can invoke APIs or trigger actions, failures or misuse can result in real-world consequences such as data loss or system reconfiguration. This challenge maps to **T2, T6, and T13**.

Question 61

An organization is implementing Zero Trust and wants its architecture to assume that an attacker may already have access to the environment.

Which principle BEST reflects the approach described in Module 7?

- A. Trust internal users but continuously monitor external users
 - B. Treat the internal network as inherently trusted
 - C. Assume compromise and continuously verify access requests
 - D. Authenticate users once and rely on network segmentation afterward
-

Question 62

A Zero Trust architecture receives a request from a user to access a sensitive AI database. The system evaluates enterprise policy, current threat intelligence, and vulnerability information before deciding whether access should be granted.

Which Zero Trust component is primarily responsible for this decision?

- A. Policy Enforcement Point
 - B. Policy Administrator
 - C. Policy Engine
 - D. IAM credential store
-

Question 63

After the Policy Engine determines that a user should receive access, another component establishes the connection and issues the required session credentials.

Which component is performing this function?

- A. Policy Engine
 - B. Policy Administrator
 - C. Policy Enforcement Point
 - D. UEBA monitoring agent
-

Question 64

A user has been granted access to an application. During the session, the system monitors the user's activity and enforces the access decision while observing the ongoing session.

Which Zero Trust component BEST fits this role?

- A. Policy Enforcement Point
 - B. Policy Engine
 - C. Policy Administrator
 - D. Threat intelligence feed
-

Question 65

A company wants to implement Zero Trust but cannot replace its existing perimeter security architecture immediately. It decides to begin by protecting its highest-value data and workflows and expand the implementation over time.

Which statement BEST reflects Module 7's guidance?

- A. Zero Trust requires immediate replacement of all perimeter controls
 - B. Zero Trust should be implemented incrementally alongside existing infrastructure
 - C. Zero Trust is only practical after all legacy infrastructure has been removed
 - D. Zero Trust applies only to cloud-native applications
-

Question 66

An organization's IAM platform uses a risk engine that assigns a real-time risk score based on device, location, and time of day. The score determines whether the user receives normal authentication, additional MFA, or is denied.

Which AI capability is being demonstrated?

- A. Static role-based authorization
 - B. Dynamic risk-based access decisions
 - C. Model extraction
 - D. Data poisoning detection
-

Question 67

A user successfully authenticates to a financial application. Ten minutes later, the user's behavior changes significantly from their normal sequence of activities. The organization automatically requests re-authentication.

Which Zero Trust capability BEST supports this control?

- A. Continuous authentication using anomaly or sequence detection
 - B. Static password authentication
 - C. Network perimeter filtering
 - D. SBOM validation
-

Question 68

A UEBA platform builds behavioral baselines for users, devices, and applications and flags activities that deviate significantly from normal behavior.

Which AI technique would be MOST appropriate for detecting such deviations without requiring labeled attack data?

- A. Supervised linear regression only
- B. Unsupervised anomaly detection

- C. Model extraction
 - D. Data anonymization
-

Question 69

A security team wants to identify unusual relationships between user accounts and devices that could indicate lateral movement by an attacker.

Which AI technique mentioned in Module 7 is MOST relevant?

- A. Graph-based learning
 - B. Data minimization
 - C. Logistic regression only
 - D. Model signing
-

Question 70

A SIEM receives millions of events per second from an enterprise environment. The security team wants to use distributed machine-learning pipelines to maintain real-time risk scoring at this scale.

Which technologies does Module 7 specifically identify as examples?

- A. Spark or Flink
 - B. Nikto or SQLmap
 - C. Sigstore or in-toto
 - D. ARX or GDPR Toolkit
-

Question 71

A security analyst reviewing a SIEM alert wants to understand why an AI model classified a particular sequence of events as suspicious.

Which tools identified in Module 7 can help provide explainability?

- A. SHAP or LIME
 - B. Syft or CycloneDX
 - C. pip-audit or Bandit
 - D. Isolation Forest or clustering
-

Question 72

A company uses a SaaS-based AI service. The cloud provider controls most of the underlying technology stack, while the enterprise primarily controls identities, data, and access policies.

Where should the organization's Zero Trust focus be concentrated?

- A. Host-level runtime monitoring of the provider's infrastructure
- B. Identity and access management, DLP, and available UEBA telemetry

- C. Physical security of the provider's servers
 - D. Operating-system patch management on the provider's infrastructure
-

Question 73

An enterprise uses a PaaS AI service. The cloud provider manages the platform, while the enterprise controls its applications and data.

Which Zero Trust controls does Module 7 emphasize for this situation?

- A. Physical access control and CCTV
 - B. API gateways, data lineage, and policy-as-code
 - C. Host telemetry and direct kernel monitoring only
 - D. Replacing the PaaS platform with an on-premises system
-

Question 74

An enterprise runs its AI workload on IaaS virtual machines and manages the infrastructure through the application layer.

Which Zero Trust capability becomes more feasible because the enterprise has greater control over the stack?

- A. Host telemetry, runtime monitoring, SIEM correlation, and micro-segmentation
 - B. Provider-side physical access management
 - C. Eliminating all identity controls because the enterprise owns the VM
 - D. Relying exclusively on the cloud provider's security controls
-

Question 75

Two cloud providers are used by an organization. An AI application runs in Cloud B while its database resides in Cloud A. The application connects directly to the database rather than routing traffic through the enterprise network.

Why does a traditional enterprise firewall provide limited protection in this scenario?

- A. The firewall cannot inspect encrypted traffic under any circumstances
 - B. Critical traffic travels directly between cloud providers outside the enterprise perimeter
 - C. Cloud applications cannot communicate with databases
 - D. Zero Trust eliminates the need for network security controls
-

Question 76

For the multi-cloud architecture in Question 75, which approach BEST aligns with the Module 7 recommendation?

- A. Route all traffic through one physical firewall regardless of performance
- B. Use a software-defined perimeter with enforcement points at application and data access points

- C. Trust all communication between approved cloud providers
 - D. Disable all cross-cloud connectivity
-

Question 77

An enterprise architect is designing a multi-cloud Zero Trust architecture. Cloud providers expose similar capabilities through different interfaces and implementation methods.

What challenge must the architect address?

- A. Eliminating all cloud providers except one
 - B. Ensuring interoperability so policies remain enforceable across heterogeneous platforms
 - C. Replacing policy engines with traditional firewalls
 - D. Disabling policy enforcement at application boundaries
-

Question 78

An organization discovers that its AI application's input data is being affected by schema inconsistencies and data-quality problems. The team wants to identify the enterprise architecture layer primarily concerned with data validation, integrity, bias, fairness, and data drift.

Which layer is this?

- A. Governance
 - B. Data and Information
 - C. Hardware
 - D. Network and Connectivity
-

Question 79

A security engineer is reviewing an AI application and identifies output validation, error handling, application hardening, patch management, configuration hardening, and dependency tracking as relevant controls.

Which enterprise architecture layer BEST corresponds to these controls?

- A. Operation
 - B. Data and Information
 - C. Software and Application
 - D. Hardware
-

Question 80

A company is protecting an AI-enabled industrial control environment. Engineers implement redundant fail-safes, physical access controls, tamper detection, and secure boot mechanisms.

Which enterprise architecture layer is MOST directly associated with these controls?

- A. Governance
 - B. Hardware
 - C. Data and Information
 - D. Software and Application
-

Answers & Explanations

Answer 61 — C. Assume compromise and continuously verify access requests

Explanation: Module 7 describes Zero Trust using the assumption that an attacker is already in the environment. No user, application, or machine is automatically trusted. Requests must be evaluated against current policies and contextual information, with least privilege and continuous authentication/authorization.

Answer 62 — C. Policy Engine

Explanation: The Policy Engine is the decision-making component—the "brain" of Zero Trust. It evaluates enterprise policies together with real-time inputs such as threat intelligence and vulnerability information to determine whether access should be granted or denied.

Answer 63 — B. Policy Administrator

Explanation: The Policy Administrator acts on the Policy Engine's decision. It establishes or terminates connections and issues session tokens or credentials needed for access.

Answer 64 — A. Policy Enforcement Point

Explanation: The Policy Enforcement Point sits between the requester and the resource. It enforces the decision made through the Policy Engine/Policy Administrator and monitors the ongoing session.

Answer 65 — B. Zero Trust should be implemented incrementally alongside existing infrastructure

Explanation: Module 7 explicitly describes Zero Trust adoption as a **journey rather than a wholesale replacement**. Organizations can begin by protecting high-value data and workflows while continuing to use existing perimeter controls during modernization.

Answer 66 — B. Dynamic risk-based access decisions

Explanation: Module 7 describes AI-enhanced IAM in which models generate real-time risk scores. Adaptive MFA can then adjust authentication requirements based on contextual factors such as device, location, and time of day.

Answer 67 — A. Continuous authentication using anomaly or sequence detection

Explanation: Zero Trust does not stop verification after initial login. Module 7 describes continuous authentication during a session, using anomaly detection or sequence models to identify unusual behavior after authentication.

Answer 68 — B. Unsupervised anomaly detection

Explanation: UEBA establishes behavioral baselines and identifies deviations. Module 7 specifically identifies **isolation forests, clustering, and autoencoders** as unsupervised anomaly-detection techniques that can identify unusual activity without requiring labeled attack examples.

Answer 69 — A. Graph-based learning

Explanation: Graph-based learning can model relationships among accounts and devices. Module 7 notes that these techniques can help uncover lateral movement that may indicate compromise.

Answer 70 — A. Spark or Flink

Explanation: Module 7 identifies distributed ML pipelines using platforms such as **Spark or Flink** as a way to maintain risk scoring at very large event volumes. The study guide specifically describes these pipelines as supporting millions of events per second.

Answer 71 — A. SHAP or LIME

Explanation: SHAP and LIME are identified in Module 7 as explainability tools that can be integrated into SIEM workflows to help analysts and auditors understand why particular events or sequences were flagged.

Answer 72 — B. Identity and access management, DLP, and available UEBA telemetry

Explanation: In SaaS, most of the technology stack is outside the enterprise's direct control. Module 7 therefore emphasizes IAM, strong data-loss-prevention rules, and UEBA based on whatever provider logs are available.

Answer 73 — B. API gateways, data lineage, and policy-as-code

Explanation: In PaaS, the provider manages the platform while the enterprise manages applications and data. Module 7 therefore shifts the Zero Trust focus toward protecting APIs with gateways, tracking data lineage, and using policy-as-code for consistent enforcement across services.

Answer 74 — A. Host telemetry, runtime monitoring, SIEM correlation, and micro-segmentation

Explanation: IaaS provides the enterprise with deeper control because it manages the infrastructure through the application layer. Module 7 identifies host telemetry, runtime monitoring, SIEM correlation, and micro-segmentation as possible deeper Zero Trust controls.

Answer 75 — B. Critical traffic travels directly between cloud providers outside the enterprise perimeter

Explanation: In the multi-cloud example, the application in one provider communicates directly with a database in another provider. Consequently, important traffic bypasses the enterprise network and its traditional firewall, creating visibility and enforcement gaps.

Answer 76 — B. Use a software-defined perimeter with enforcement points at application and data access points

Explanation: Module 7 recommends an **SDP-based Zero Trust model** for this multi-cloud situation. Policy Enforcement Points are placed at application and data access points, while the Policy Engine and Policy Administrator make and execute access decisions.

Answer 77 — B. Ensuring interoperability so policies remain enforceable across heterogeneous platforms

Explanation: Cloud providers may implement similar functions differently. Module 7 therefore emphasizes interoperability when designing multi-cloud Zero Trust architectures so that security policies remain enforceable across heterogeneous platforms.

Answer 78 — B. Data and Information

Explanation: The Data and Information layer addresses data integrity, correctness checks, schema validation, input-data bias and fairness monitoring, and data-drift monitoring. Its security controls include encryption, access controls, integrity checks, provenance, and DLP.

Answer 79 — C. Software and Application

Explanation: The Software and Application layer includes reliable execution of safety-critical software, error handling, output validation, application hardening, patch/vulnerability management, secure updates, configuration hardening, and SBOM-based dependency tracking.

Answer 80 — B. Hardware

Explanation: The Hardware layer covers physical devices, machinery, servers, and IoT/OT systems. Safety controls include protective equipment, environmental safeguards, condition monitoring, and redundant fail-safes; security controls include physical access control, tamper detection, secure boot, and CCTV monitoring.

Question 81

An autonomous AI system consistently pursues an optimization objective but begins taking actions that technically maximize its reward while producing outcomes that conflict with the organization's intended purpose.

Which concept BEST describes the underlying concern?

- A. Data drift
 - B. AI alignment
 - C. Model extraction
 - D. Resource overload
-

Question 82

An organization is designing an AI system for a safety-critical environment. The team wants to ensure that improvements in one capability do not unintentionally create new dangerous capabilities elsewhere in the organization.

Which principle from Module 7 is MOST relevant?

- A. Minimal capability externalities
 - B. Maximum autonomous capability
 - C. Perimeter trust
 - D. Model extraction resistance
-

Question 83

An industrial company creates a virtual representation of a physical production system. The virtual system continuously receives real-time operational data and is used to predict failures and recommend actions.

What technology is being described?

- A. UEBA
 - B. Digital twin
 - C. Policy Engine
 - D. SIEM
-

Question 84

A digital twin of an industrial process identifies an abnormal operating condition and recommends a change intended to prevent equipment failure.

Which capability of a digital twin is MOST directly demonstrated?

- A. Predicting failures and prescribing real-time actions
- B. Extracting proprietary model functionality
- C. Preventing identity spoofing
- D. Performing data anonymization

Question 85

A company's LLM-powered assistant provides customers with recommendations based on information found on the public web. Attackers deliberately create websites designed to appear authoritative so that the LLM incorporates those sites into its recommendations.

Which LLM abuse technique from Case Study #1 is being demonstrated?

- A. Scam chatbot creation
- B. Web data contamination
- C. Model inversion
- D. Resource overload

Question 86

An attacker wants to create a convincing phishing website but encounters safety restrictions in a commercial LLM. Instead of asking directly for a phishing site, the attacker asks the LLM to generate prompts based on the design of a well-known brand.

Which technique from Case Study #1 does this BEST represent?

- A. Website creation for phishing attacks
- B. Web data contamination
- C. Data poisoning
- D. Agent communication poisoning

Question 87

A criminal uses publicly available information about a victim to create a personalized chatbot that imitates a convincing human interaction and conducts a long-term scam.

Which LLM exploitation technique is MOST directly represented?

- A. Web data contamination
- B. Scam chatbot creation
- C. Model extraction
- D. Prompt injection

Question 88

A security team is designing safeguards against automated scam chatbots. The team wants to make long-running scam conversations less consistent and therefore easier for humans to detect.

According to Case Study #1, which measure could help achieve this objective?

- A. Increase the model's context window indefinitely
- B. Restrict the context window while balancing normal functionality

- C. Disable all text-to-speech capabilities across the Internet
 - D. Eliminate all public-facing chatbots
-

Question 89

A provider is attempting to distinguish legitimate use of an LLM from malicious use. The same capabilities could potentially support either normal customer service or an automated scam.

What challenge identified in Case Study #1 makes this difficult?

- A. Benign vs. malicious intent
 - B. Data residency
 - C. Model extraction
 - D. Hardware isolation
-

Question 90

An organization discovers that attackers continuously modify their techniques in response to new AI safety controls and increasingly capable AI tools.

Which Case Study #1 risk consideration does this BEST represent?

- A. User experience
 - B. Constantly evolving threats
 - C. Data minimization
 - D. Static authorization
-

Question 91

A multinational organization uses AI agents across supply chains, product design, business analytics, and customer support. The agents can access sensitive information across multiple business units and countries.

What is the PRIMARY security challenge emphasized in Case Study #2?

- A. Ensuring sensitive data is accessible only to the appropriate agents and contexts
 - B. Eliminating all AI agents from multinational operations
 - C. Allowing all agents unrestricted access to maximize efficiency
 - D. Moving all data to a single country
-

Question 92

A sales-prediction AI agent operating in one country attempts to combine data from several other regions even though its approved use case is limited to localized predictions.

Which Case Study #2 requirement is MOST directly violated?

- A. The requirement that agents access data only under the approved context
- B. The requirement to maximize data pooling

- C. The requirement to eliminate anonymization
 - D. The requirement to centralize all governance in one jurisdiction
-

Question 93

A multinational organization processes AI data in several countries. Each jurisdiction has different regulatory and compliance requirements.

Which approach BEST aligns with Case Study #2?

- A. Apply identical data-validation rules regardless of jurisdiction
 - B. Use dynamic data validation and shared data/model governance across jurisdictions
 - C. Allow individual agents to determine their own compliance requirements
 - D. Ignore local requirements if the organization has a global security policy
-

Question 94

An organization has limited historical data from one country compared with another. The AI system therefore performs significantly better for one region than another.

Which concern from Case Study #2 is MOST relevant?

- A. Bias across cultural contexts caused by unbalanced data
 - B. Model extraction
 - C. Tool misuse
 - D. Resource overload
-

Question 95

A multinational company wants to prevent AI agents from accessing information outside their authorized business context while maintaining real-time enforcement with minimal friction for employees.

Which capability is MOST aligned with Case Study #2?

- A. Data-flow visibility and real-time access enforcement
 - B. Unrestricted data pooling
 - C. Static annual access reviews only
 - D. Removal of all AI automation
-

Question 96

An organization wants to reduce the risk of sensitive information being exposed when AI agents operate across multiple countries.

Which combination is specifically emphasized in the Case Study #2 key takeaways?

- A. Layered data access and appropriate anonymization
- B. Public data sharing and unrestricted access

- C. Single-factor authentication and centralized storage
 - D. Model extraction and adversarial examples
-

Question 97

An organization has implemented encryption, access controls, data lineage, and DLP for its AI data. It also wants to determine whether the source data itself has been maliciously manipulated before entering the model-training process.

Which additional control BEST addresses this requirement?

- A. Data poisoning defense and auditing of external data sources
 - B. Adaptive MFA only
 - C. Policy Enforcement Point only
 - D. Physical CCTV monitoring
-

Question 98

A company discovers an AI system operating without approval. Employees deployed it independently, and the organization has little visibility into what data is being sent to the service.

Which combination of Module 7 concepts is MOST relevant?

- A. Shadow AI and governance over AI-tool onboarding
 - B. Data drift and digital twins
 - C. Model extraction and resource overload
 - D. Red teaming and penetration testing only
-

Question 99

A security team wants to protect an AI system used in a safety-critical process. The team proposes:

- monitoring model outputs for unsafe recommendations,
- documenting low-confidence outputs,
- validating input data,
- enforcing secure model execution,
- monitoring the network,
- and maintaining human oversight.

What is the BEST interpretation of this design?

- A. It applies only traditional cybersecurity controls
 - B. It applies the enterprise architecture framework across multiple AI safety and security layers
 - C. It focuses exclusively on model confidentiality
 - D. It eliminates the need for governance
-

Question 100

An organization deploys an autonomous AI agent with access to sensitive data and external tools. A comprehensive security program is being designed.

Which approach BEST represents the overall philosophy of Module 7?

- A. Focus exclusively on protecting the model because the model is the primary asset
 - B. Treat AI safety and AI security as separate and unrelated disciplines
 - C. Combine traditional IT/OT controls with AI-specific and AI-adapted controls across governance, operations, data, hardware, software, and network layers
 - D. Rely entirely on Zero Trust because AI-specific controls are unnecessary
-

Answers & Explanations

Answer 81 — B. AI alignment

Explanation: AI alignment keeps AI goals and behavior consistent with human values and intended outcomes. Module 7 specifically identifies reward hacking, bias, and unintended side effects as concerns associated with alignment.

Answer 82 — A. Minimal capability externalities

Explanation: Module 7 introduces **minimal capability externalities** as a safety principle. Organizations should improve system reliability without inadvertently expanding capabilities that could create new dangers elsewhere in the organization.

Answer 83 — B. Digital twin

Explanation: A digital twin is a set of adaptive models that emulate the behavior of a physical system in a virtual environment. It receives real-time data throughout the system's lifecycle and can be used to predict failures, prescribe actions, and evaluate operating conditions.

Answer 84 — A. Predicting failures and prescribing real-time actions

Explanation: The study guide identifies two important digital-twin capabilities: predicting failures/opportunities and prescribing real-time actions to optimize operations or mitigate unexpected events.

Answer 85 — B. Web data contamination

Explanation: Case Study #1 describes attackers tailoring websites and other web sources, such as GitHub pages and blogs, to appear trustworthy to LLM-based systems. This can result in LLMs recommending phishing sites or incorporating incorrect APIs and malicious code into coding projects.

Answer 86 — A. Website creation for phishing attacks

Explanation: The case study notes that commercial LLMs may contain safeguards against directly creating phishing websites. Attackers may instead ask the LLM to create prompts for website creation based on designs inspired by well-known brands.

Answer 87 — B. Scam chatbot creation

Explanation: Case Study #1 describes how attackers can use publicly available information and web scraping to build profiles of targets and then create personalized phishing websites and chatbots. Text-to-speech capabilities can make these interactions appear more human and convincing.

Answer 88 — B. Restrict the context window while balancing normal functionality

Explanation: The study guide identifies context-window restriction as one measure that can make scam chatbots less self-consistent and more susceptible to human detection. However, it explicitly states that this must be balanced against normal functionality and responsiveness.

Answer 89 — A. Benign vs. malicious intent

Explanation: The same LLM capabilities can support legitimate and malicious activities. The study guide notes that identifying user intent requires extensive context, making it difficult to distinguish benign use from malicious use. Providers can use measures such as detecting high volumes of unusual activity.

Answer 90 — B. Constantly evolving threats

Explanation: The case study identifies constantly evolving threats as a key challenge because attackers adapt their techniques in response to safety measures and increasingly capable AI tools. The study guide recommends combining AI/LLMs with human experts for red teaming to identify emerging vulnerabilities.

Answer 91 — A. Ensuring sensitive data is accessible only to the appropriate agents and contexts

Explanation: Case Study #2 emphasizes that multinational AI-agent architectures may have visibility into sensitive information across business units and jurisdictions. A major requirement is ensuring that sensitive data is available only to the agents that need it and only within the approved context.

Answer 92 — A. The requirement that agents access data only under the approved context

Explanation: The case study gives the example of a sales-prediction module that should not pool information from multiple regions when performing a localized prediction. Data access therefore needs to be constrained according to the approved business context.

Answer 93 — B. Use dynamic data validation and shared data/model governance across jurisdictions

Explanation: Case Study #2 recognizes that multinational operations involve different languages, jurisdictions, cultural contexts, and compliance requirements. Its key takeaways emphasize that data-validation requirements are dynamic across contexts and that data and model governance are essential.

Answer 94 — A. Bias across cultural contexts caused by unbalanced data

Explanation: Case Study #2 specifically identifies unbalanced data as a concern when some regions have less operational history or weaker data-collection capabilities. This can introduce differences in agent behavior across cultural contexts and therefore requires active bias reduction.

Answer 95 — A. Data-flow visibility and real-time access enforcement

Explanation: The case study describes the need for an AI solution that manages access to critical data according to business-specific rules while providing visibility into data flows and real-time enforcement. The objective is to maintain AI functionality while minimizing friction for end users.

Answer 96 — A. Layered data access and appropriate anonymization

Explanation: One of the explicit Case Study #2 key takeaways is that **layered access to data and appropriate anonymization are key** for multinational operations. These controls help limit unnecessary exposure of sensitive information across countries and organizational contexts.

Answer 97 — A. Data poisoning defense and auditing of external data sources

Explanation: The Data and Information layer includes traditional data-protection controls such as encryption, access controls, integrity checks, lineage/provenance, and DLP. AI-specific security additionally requires defenses against data poisoning and auditing of external data sources.

Answer 98 — A. Shadow AI and governance over AI-tool onboarding

Explanation: Module 7 identifies shadow AI as a governance concern because employees may deploy unapproved or unmanaged AI tools without understanding how information is stored, shared, or exposed. The AI-specific Governance layer therefore includes policy for onboarding AI tools, including validation of MCP servers, and governance over shadow AI.

Answer 99 — B. It applies the enterprise architecture framework across multiple AI safety and security layers

Explanation: Module 7 explicitly extends the enterprise architecture framework to AI safety and security. Each layer contains baseline IT/OT controls plus AI-specific or AI-adapted controls.

Examples include hallucination monitoring at the Operation layer, training-data integrity at the Data layer, secure model execution at the Hardware layer, and prompt-injection detection at the Operation/Security layer.

Answer 100 — C. Combine traditional IT/OT controls with AI-specific and AI-adapted controls across governance, operations, data, hardware, software, and network layers

Explanation: This is the central architectural approach of Module 7. AI systems should not be secured by treating the model as an isolated component. The study guide extends traditional IT/OT safety and security practices across the enterprise architecture and adds **AI-specific controls**—such as prompt-injection detection—and **AI-adapted controls**, such as interpreting data integrity to include representativeness and fairness of training data.